

Rapport technique final - version consolidee

SOC externalise pour un reseau d'audioprothesistes

Rapport technique final - version consolidee

Page 1 - Page de garde et synthese

Projet : Mise en place d'un SOC externalise pour un reseau d'audioprothesistes.

Equipe : Yvan FOCSA, Youssef GUERNIOU, Kilyan FELIX, Mahamadou DIACOUMBA.

Client de demonstration : Daylight, reseau fictif representant environ 30 centres d'audioprothesistes en France.

Prestataire de demonstration : CT - Cyber Threat, SOC externalise fictif.

Ce rapport presente la conception, la mise en place et l'industrialisation d'un SOC externalise. Il couvre le cadrage du besoin, l'architecture cible, le choix de Wazuh, la strategie de collecte, les regles de detection, les dashboards, les playbooks de reponse incident, les tests realises, les couts, les limites et les perspectives.

Cette version consolidee regroupe le rapport, les preuves de logs, les regles de detection, les captures dashboard et les annexes utiles pour la soutenance. Les preuves prioritaires sont les captures Wazuh live du dossier livrables/preuves/wazuh-live-captures/, generees apres lancement de la stack Wazuh 4.14.5 et injection des logs Daylight du MVP.

Page 2 - Table de lecture du rapport

Le rapport est organise pour suivre la logique attendue dans le cadre pedagogique : comprendre le besoin, justifier la solution, demontrer le MVP, documenter les preuves et proposer une trajectoire d'industrialisation.

Partie | Contenu

Cadrage | Contexte, objectifs, problematique et perimetre.

Architecture | Architecture logique, architecture Docker MVP, architecture cible production.

Collecte | Sources de logs, formats, flux et briques SI supervisees.

Detection | Regles Wazuh, niveaux de criticite, scenarios et alertes.

Reponse | Playbooks, qualification, REX et amelioration continue.

Pilotage | Organisation, planning, couts, risques et livrables.

Industrialisation | Passage du MVP aux 30 sites, onboarding et exploitation.

Annexes | Preuves, regles, logs, dashboards, scripts et guides.

Chaque page est concue comme une section autonome. Cela facilite la relecture, la transformation en PDF, l'ajout de captures et la repartition du travail entre les membres de l'equipe.

Page 3 - Contexte client

Daylight represente un reseau d'audioprothesistes compose d'environ 30 points de vente. Chaque centre dispose de postes de travail utilises par les audioprothesistes, d'applications metier pour les rendez-vous et dossiers patients, d'une messagerie professionnelle, de serveurs internes et d'equipements reseau.

Le contexte est sensible car l'activite manipule des informations personnelles et medicales. Une fuite de donnees, une indisponibilite applicative ou une compromission de compte peut avoir des impacts importants : perte de confiance, interruption de service, non-conformite et risque juridique.

Le client ne dispose pas d'une equipe interne suffisante pour exploiter un SOC complet. Il recherche donc une solution externalisee, capable de centraliser les evenements de securite et de fournir une supervision claire.

Enjeu | Description

Confidentialite | Proteger les informations clients et dossiers patients.

Disponibilite | Maintenir les services metier disponibles dans les centres.

Tracabilite | Conserver les evenements utiles pour comprendre un incident.

Reactivite | Detecter et qualifier rapidement les alertes.

Industrialisation | Deployer le modele sur plusieurs sites sans repartir de zero.

Page 4 - Objectifs du projet

L'objectif principal est de concevoir un démonstrateur de SOC externalisé, fonctionnel et documenté. Le SOC doit centraliser les logs, détecter les comportements suspects, afficher des dashboards et guider la réponse incident.

Les objectifs techniques sont les suivants :

- déployer un SIEM open-source centralisé ;
- collecter des logs multi-sources ;
- créer des règles de détection adaptées au contexte client ;
- produire des alertes exploitables ;
- fournir une interface web de supervision ;
- structurer des playbooks de réponse incident ;
- documenter une architecture reproductible.

Les objectifs projet sont complémentaires :

- organiser l'équipe autour de rôles clairs ;
- produire un rapport technique complet ;
- préparer une vidéo MVP de 15 à 20 minutes ;
- montrer une posture de prestataire externe ;
- justifier les choix techniques par rapport au cahier des charges.

Le projet doit donc prouver à la fois une compétence technique et une capacité de communication professionnelle.

Page 5 - Problematique

La problematique retenue est la suivante :

Comment concevoir un SOC externalise open-source, securise, lisible et industrialisable, capable de superviser un reseau multi-sites d'audioprothesistes et de detecter les evenements critiques sur les principales briques du systeme d'information ?

Cette problematique implique plusieurs dimensions. La premiere est technique : il faut collecter des logs heterogenes et les transformer en alertes exploitables. La deuxieme est organisationnelle : les roles et procedures doivent permettre a une equipe SOC d'agir efficacement. La troisieme est documentaire : les livrables doivent permettre au jury et au client de comprendre la solution.

Le projet n'a pas vocation a deployer un SOC 24/7 complet en production. Il vise a construire un MVP credible, capable de demontrer la chaine de valeur SOC : collecte, detection, qualification, reponse, preuve et amelioration continue.

Page 6 - Perimetre du MVP

Le cahier des charges mentionne environ 30 points de vente. Pour un projet d'etudes, il n'est pas realiste de reproduire un parc complet. Le perimetre MVP consiste donc a simuler les briques importantes et a prouver que le modele peut etre industrialise.

Element | Decision MVP | Justification

Nombre de sites | Sites simules representatifs | Prouver le modele sans complexite excessive.

SOC | Wazuh single-node Docker | Rapidite, reproductibilite et cout maitrise.

Logs | Logs realistes rejoues | Demo stable et tests reproductibles.

Endpoints | Logs endpoint et option agent reel | Couverture des postes utilisateurs.

Reseau | Syslog firewall simule | Couverture routeur/firewall.

Applications | Logs CRM/RDV/patients | Couverture donnees metier sensibles.

Reponse | Playbooks Markdown | Lisibles, versionnables, auditables.

Cette approche est assumee dans le rapport : Docker sert au MVP, pas a représenter integralement la production finale.

Page 7 - Hypotheses et contraintes

Plusieurs hypotheses structurent le projet. Elles doivent etre explicites afin d'eviter toute ambiguïte devant le jury.

Hypothese | Impact

Les donnees sont fictives | Aucune donnee patient reelle n'est manipulee.

Le client est simule | Daylight sert de mise en situation.

Les logs sont rejoues | La demo reste stable et reproductible.

Docker est utilise | Les services sont legers et faciles a redemloyer.

La production serait differente | Certains composants deviendraient des VMs ou actifs reels.

Les contraintes principales sont le temps, la disponibilite materielle, la complexite de Wazuh et la necessite de produire des livrables comprehensibles.

La contrainte la plus importante est la stabilite de la demonstration. Il vaut mieux un scenario de detection parfaitement maitrise qu'une architecture trop ambitieuse et instable.

Page 8 - Organisation de l'equipe

L'equipe est composee de quatre membres avec des responsabilites complementaires.

Membre | Role | Responsabilites principales

Kilyan FELIX | Chef de projet / referent client | Cadrage, planning, couts, rapport, video.

Yvan FOCSA | Architecte infrastructure / reseau | Architecture, flux, syslog, industrialisation.

Youssef GUERNIOU | Ingenieur SIEM | Wazuh, collecte, agents, dashboards, RBAC.

Mahamadou DIACOUMBA | Analyste SOC | Scenarios, regles, alertes, playbooks, REX.

Cette repartition couvre les attentes du projet : analyse, conception, deploiement, detection, reponse, documentation et communication.

Le fonctionnement retenu est agile hybride. Chaque fonctionnalite doit produire une preuve technique, une preuve documentaire et un moment de demonstration video.

Page 9 - Architecture globale

L'architecture globale repose sur un SOC externalise centralise. Les sites clients envoient leurs evenements de securite vers la plateforme SOC. Les analystes consultent les alertes depuis l'interface web, appliquent les playbooks et produisent un reporting.

Zone | Role

Sites Daylight | Produire les logs endpoint, reseau, applicatifs, AD et messagerie.

Reseau de collecte | Transporter les evenements vers le SOC.

SOC CT - Cyber Threat | Centraliser, analyser et afficher les alertes.

Analystes SOC | Qualifier et traiter les incidents.

Direction client | Lire les rapports et suivre les risques.

Le modele est compatible avec une exploitation externalisee car le SIEM est centralise cote prestataire. Les sites clients restent sources d'evenements et le prestataire assure la supervision.

Page 10 - Architecture logique

L'architecture logique se compose de cinq couches :

Couche | Description

Collecte | Agents, syslog, logs applicatifs et logs simules.

Transport | Acheminement des evenements vers Wazuh.

Analyse | Decoders, regles, correlation et niveaux d'alerte.

Visualisation | Dashboards, filtres et recherche.

Reponse | Playbooks, actions de confinement et reporting.

Cette separation permet d'expliquer clairement le role de chaque composant. Elle facilite aussi l'industrialisation : un nouveau site doit simplement integrer les couches collecte et transport pour rejoindre le SOC central.

La logique est la suivante : un evenement apparait sur une machine ou un service, il est collecte, transmis, analyse, transforme en alerte si necessaire, puis traite par l'analyste.

Page 11 - Architecture MVP Docker

Le MVP utilise Docker pour exécuter la stack Wazuh et simuler certaines briques du SI client. Cette décision permet d'obtenir un environnement léger, reproductible et transportable.

Conteneur / service | Role

Wazuh Manager | Recoit les logs, applique les regles, genere les alertes.

Wazuh Indexer | Stocke et indexe les evenements.

Wazuh Dashboard | Fournit l'interface web de supervision.

Generateurs de logs | Produisent des evenements Daylight realistes.

Rejeu de logs | Permet de redemontrer les alertes a la demande.

Docker ne remplace pas tous les actifs de production. Il permet de simuler le fonctionnement du SOC et de valider la chaine technique. Pour la production, les postes, serveurs et firewalls seraient des équipements reels ou des VMs.

Page 12 - Justification du choix Docker

Le choix de Docker est pertinent pour un démonstrateur pour plusieurs raisons. Il réduit le temps d'installation, limite les besoins matériels, facilite le redéploiement et rend la démonstration plus stable.

Avantage | Explication

Reproductibilité | Les conteneurs peuvent être relancés avec la même configuration.

Légereté | Moins lourd que plusieurs VMs complètes.

Rapidité | Installation plus rapide pour le MVP.

Stabilité demo | Les logs peuvent être rejoués si besoin.

Portabilité | Le projet peut être partagé plus facilement.

La limite est que Docker ne reproduit pas parfaitement un endpoint Windows, un Active Directory complet ou un firewall physique. Cette limite est acceptable si elle est clairement expliquée dans le rapport et dans la vidéo.

Page 13 - Architecture cible production

En production, l'architecture serait plus robuste que le MVP Docker. Les sites Daylight disposeraient de postes reels, serveurs internes, applications de production et firewalls. Les logs seraient transmis vers le SOC externalise.

Composant production | Evolution par rapport au MVP
Postes Windows | Agents Wazuh reels, Sysmon possible.
Serveurs internes | Agents Wazuh et surveillance fichiers.
Active Directory | Logs authentication, groupes, GPO.
Firewalls | Syslog direct vers le SOC.
Messagerie | Logs mail, phishing, pieces jointes.
SOC | Architecture haute disponibilite a envisager.

Le passage en production demanderait aussi une politique de retention, des sauvegardes, une supervision de la sante du SIEM, du RBAC et une procedure de maintien en condition de securite.

Page 14 - Flux reseau

Les flux reseau doivent etre documentes pour demontrer que la solution est securisee et maitrisable.

Flux | Source | Destination | Usage

Agent Wazuh | Poste / serveur | Wazuh Manager | Collecte endpoint.

Syslog | Firewall | Wazuh Manager | Logs reseau.

HTTPS | Analyste | Wazuh Dashboard | Consultation interface web.

API Wazuh | Dashboard | Manager | Requetes internes.

Indexation | Manager | Indexer | Stockage evenements.

En production, ces flux devraient etre limites par pare-feu, journalises et documentes dans un dossier d'exploitation. Les flux d'administration devraient etre separes des flux utilisateurs.

Page 15 - Zones de securite

Une architecture SOC propre doit distinguer les zones de securite. Cette separation reduit les risques de compromission laterale et clarifie les responsabilites.

Zone | Description

Zone site client | Postes, applications, serveurs et firewall du centre.

Zone collecte | Flux agents, syslog et logs applicatifs.

Zone SOC | Wazuh Manager, Indexer, Dashboard et stockage.

Zone administration | Acces admin restreints au SIEM.

Zone reporting | Exports et rapports clients.

Le principe est de limiter les acces au strict necessaire. Un utilisateur client ne doit pas administrer le SIEM, un analyste ne doit pas modifier l'infrastructure sans controle et les flux de logs doivent rester fiables.

Page 16 - Composants Wazuh

Wazuh est compose de plusieurs briques.

Composant | Role

Wazuh Manager | Centralise les evenements et applique les regles.

Wazuh Indexer | Stocke et indexe les donnees.

Wazuh Dashboard | Fournit l'interface web.

Agents | Collectent les evenements sur endpoints et serveurs.

Rules | Definissent les conditions d'alerte.

Decoders | Interpretent les formats de logs.

Dans le sprint 01, les preuves montrent que la stack Wazuh est active et que les services essentiels fonctionnent. Cette base technique rend possible les phases suivantes : integration de logs, creation de regles et creation de dashboards.

Le script scripts/setup-siem-lab.ps1, fourni a partir du travail de Youssef, complete ce socle. Il automatise le serveur Linux simule serveur-01, l'agent Wazuh, la collecte SSH via /var/log/auth.log, le test brute force et le RBAC de demonstration.

Page 17 - Manager, Indexer et Dashboard

Le Manager est le coeur du SIEM. Il recoit les logs, les analyse et genere des alertes. L'Indexer stocke les evenements pour permettre la recherche et la visualisation. Le Dashboard donne acces aux analystes et administrateurs.

Service | Importance

Manager | Indispensable pour la detection.

Indexer | Indispensable pour historique et recherche.

Dashboard | Indispensable pour exploitation humaine.

La preuve docker-compose-ps.txt montre que les conteneurs sont actifs. La preuve wazuh-manager-status.txt montre que plusieurs services internes Wazuh sont en cours d'execution.

La preuve documentaire SIEM de Youssef est conservee dans livrables/youssef/supports/Documentation_SIEM_Youssef_GUERNIOU.pdf. Elle decrit notamment la stack Wazuh 4.14.5, les sources poste-01 et serveur-01, les dashboards et la reprise du lab apres redemarrage.

Page 18 - Sources de logs

Le cahier des charges demande une collecte multi-source. Le MVP couvre plusieurs familles.

Source | Exemple de log | Risque couvert

Endpoint | PowerShell suspect, USB | Malware, execution suspecte, exfiltration.

Firewall | Brute force, trafic refuse | Acces non autorise, reconnaissance.

Application metier | Acces dossier patient | Atteinte confidentialite.

Active Directory | Groupe privilege modifie | Elevation de privileges.

Messagerie | Phishing | Compromission initiale.

La richesse des sources est essentielle. Un SOC ne doit pas dependre d'une seule brique : il doit pouvoir corréler endpoint, reseau, identite et application.

Page 19 - Logs endpoint

Les postes de travail sont une surface d'attaque majeure. Les audioprothésistes utilisent les postes au quotidien, consultent les applications métier et peuvent recevoir des emails ou connecter des supports amovibles.

Les logs endpoint permettent de détecter :

- execution PowerShell suspecte ;
- processus anormal ;
- usage USB ;
- authentification locale ;
- modification de fichiers ;
- comportement post-phishing.

Dans le MVP, le fichier daylight-endpoint-events.jsonl sert à simuler cette activité. En production, un agent Wazuh sur poste Windows ou Linux collecterait les événements système et sécurité. Sysmon pourrait être ajouté pour obtenir des événements plus fins sur les processus et connexions.

Page 20 - Logs firewall et syslog

Les firewalls et routeurs fournissent une vision des flux réseau. Ils permettent de détecter des connexions refusées, des scans, des tentatives d'accès distant et des anomalies de trafic.

Dans le MVP, le fichier daylight-firewall-syslog.log simule des événements firewall. Une règle Wazuh détecte notamment une suspicion de brute force sur accès distant.

En production, chaque firewall de centre pourrait envoyer ses logs en syslog vers le SOC. Il faudrait documenter :

- l'adresse du collecteur ;
- le protocole et le port ;
- le format des logs ;
- la convention de nommage du site ;
- les tests de validation.

Ces logs sont essentiels pour surveiller les accès non autorisés et les flux suspects.

Page 21 - Logs applicatifs metier

Les applications metier sont critiques car elles traitent les rendez-vous, les informations clients et les dossiers patients. Une compromission applicative ou un abus de droits peut avoir un impact fort.

Dans le MVP, le fichier daylight-app-events.jsonl simule des evenements applicatifs. Le scenario principal est l'acces anormal a un volume important de dossiers patients par un compte temporaire.

Une production reelle devrait collecter :

- authentications applicatives ;
- erreurs repetees ;
- acces aux dossiers sensibles ;
- exports de donnees ;
- changements de droits ;
- actions administratives.

Ces logs permettent de relier le risque cyber au risque metier, ce qui est tres important pour convaincre le client.

Page 22 - Logs Active Directory

Active Directory ou un service d'annuaire equivalent est une brique sensible. Il gere les comptes, groupes, droits et authentications.

Dans le MVP, des logs AD simules permettent de detecter l'ajout d'un compte a un groupe privilegie. Cette alerte est critique car elle peut indiquer une elevation de privileges ou une persistance attaquant.

En production, les evenements a surveiller seraient :

- creation ou suppression de compte ;
- ajout a un groupe admin ;
- changement de mot de passe ;
- verrouillage ou deverrouillage compte ;
- connexion hors horaires ;
- modification de GPO.

Ces evenements doivent etre traites avec une criticite forte, surtout lorsqu'ils touchent des comptes privileges.

Page 23 - Logs messagerie et phishing

La messagerie est souvent le point d'entree d'une attaque. Le phishing peut mener a un vol d'identifiants, une execution de malware ou un acces non autorise aux applications.

Le MVP couvre partiellement ce risque via le scenario execution PowerShell suspecte, qui peut représenter une suite post-phishing. Une evolution logique consiste a ajouter des logs mail dedies.

Les logs utiles seraient :

- email suspect reçu ;
- domaine expéditeur anormal ;
- piece jointe bloquee ;
- URL suspecte ;
- clic utilisateur ;
- quarantaine antivirus.

Le playbook phishing doit prévoir la recherche d'emails similaires, le blocage du domaine, l'analyse du poste et la sensibilisation utilisateur.

Page 24 - Format et normalisation des logs

La normalisation des logs est importante pour permettre la recherche et les dashboards. Un log doit contenir des champs utiles : timestamp, site, hostname, utilisateur, source, scenario, action, criticite et message.

Champ | Utilite

timestamp | Reconstruire la chronologie.

site | Filtrer par centre.

hostname | Identifier la machine.

user | Identifier le compte.

source | Distinguer endpoint, firewall, app, AD, mail.

scenario | Relier l'evenement a un cas d'usage.

severity | Prioriser l'analyse.

Une bonne normalisation reduit le temps d'investigation. Sans champs clairs, l'analyste doit lire manuellement des logs bruts, ce qui ralentit la reponse.

Page 25 - Strategie de detection

La strategie de detection repose sur des cas d'usage concrets plutot que sur une collecte passive. Chaque regle doit repondre a un risque.

Risque | Detection

Malware ou script suspect | Execution PowerShell anormale.

Compromission compte | Brute force ou succes apres echecs.

Atteinte donnees patients | Volume anormal d'accès applicatifs.

Elevation privileges | Modification groupe privilegie.

Exfiltration locale | Usage USB suspect.

Reconnaissance reseau | Scan ou connexions refusees repetees.

Une detection utile doit etre comprehensible, testable et associee a un playbook. Le but n'est pas de multiplier les alertes, mais de produire des alertes exploitables.

Page 26 - Regles Wazuh

Les regles Wazuh personnalisees sont stockees dans etape 1/detection/wazuh/local_rules.xml. Elles sont la traduction technique des scenarios de detection.

ID	Niveau	Description
100100	10	Execution PowerShell suspecte.
100110	12	Brute force acces distant.
100120	10	Acces anormal dossiers patients.
100130	14	Modification groupe privilege.
100140	7	Usage USB detecte.
100150	10	Suspicion phishing messagerie.
100160	8	Suspicion scan reseau.

Les niveaux d'alerte permettent de prioriser. Une modification de groupe privilege est plus critique qu'un simple usage USB, meme si les deux doivent etre investigues.

En production, ces regles devraient etre enrichies avec des decoders plus robustes et des exceptions metier.

Page 27 - Niveaux de criticite

La criticite aide l'analyste a prioriser. Elle doit prendre en compte la nature de l'evenement, la source, le compte cible et l'impact potentiel.

Niveau | Interpretation | Exemple

Faible | Evenement a surveiller | Activite inhabituelle non critique.

Moyen | Investigation necessaire | Usage USB ou comportement endpoint.

Eleve | Risque significatif | PowerShell suspect, brute force.

Critique | Action urgente | Groupe privilegie modifie.

La criticite ne doit pas etre figee. Un evenement moyen peut devenir critique s'il touche un serveur sensible ou un compte admin. Le SOC doit donc enrichir l'alerte avec le contexte.

Page 28 - Dashboard supervision globale

Le dashboard supervision globale s'adresse au superviseur SOC et au client. Il doit donner une vision rapide de la posture securite.

Widgets attendus :

- nombre total d'alertes ;
- alertes par criticite ;
- alertes par site ;
- alertes par source ;
- top machines concernees ;
- timeline 24 heures ;
- incidents ouverts / clos.

Ce dashboard doit etre lisible pour un public non expert. Il ne doit pas afficher uniquement des logs bruts, mais des indicateurs synthetiques. Il sert a comprendre rapidement si la situation est normale ou si une action est necessaire.

Page 29 - Dashboard analyste SOC

Le dashboard analyste SOC doit aider a investiguer. Il doit afficher les alertes recentes et les details utiles.

Champs importants :

- ID regle ;
- criticite ;
- timestamp ;
- site ;
- hostname ;
- utilisateur ;
- source IP ;
- message ;
- scenario ;
- lien vers playbook.

L'analyste doit pouvoir filtrer par site, criticite, source et periode. Le dashboard doit faciliter le passage de l'alerte a l'action. Une bonne vue analyste reduit le temps de qualification et limite les erreurs.

Page 30 - Dashboard administration technique

Le dashboard administration technique permet de surveiller la sante de la plateforme.

Indicateurs utiles :

- etat des agents ;
- sources silencieuses ;
- volume d'evenements par source ;
- erreurs de parsing ;
- etat des services Wazuh ;
- espace disque ;
- retard d'indexation ;
- version des composants.

Cette vue est importante car un SOC peut sembler calme alors que certaines sources ne remontent plus de logs. La supervision de la collecte est donc aussi importante que la detection des attaques.

Page 31 - Scenario 1 : PowerShell suspect

Le scenario PowerShell suspect represente une execution de commande anormale sur un poste d'audioprothesiste. Il peut correspondre a une tentative de malware, a une action post-phishing ou a un script non autorise.

Element | Detail
Regle | 100100
Niveau | 10
Source | Logs endpoint
Technique MITRE | T1059.001
Risque | Execution de payload

Reponse attendue : identifier le poste, verifier l'utilisateur, rechercher les connexions sortantes, isoler la machine si l'activite est confirmee et conserver les logs pour investigation.

Ce scenario est fort pour la video car il montre clairement la valeur endpoint du SOC.

Page 32 - Scenario 2 : Brute force acces distant

Le scenario brute force represente plusieurs tentatives d'accès distant non autorisées. Il est détecté à partir des logs firewall/syslog.

Element | Detail
Regle | 100110
Niveau | 12
Source | Firewall/syslog
Technique MITRE | T1110
Risque | Compromission de compte

Reponse attendue : identifier l'IP source, vérifier si une connexion a réussi, bloquer la source si elle est non légitime, recommander MFA ou VPN, documenter l'incident.

Ce scenario répond directement au besoin de supervision des routeurs/firewalls.

Page 33 - Scenario 3 : Acces anormal dossier patient

Ce scenario est central pour le contexte audioprothesiste. Il represente un compte qui consulte un volume inhabituel de dossiers patients.

Element | Detail

Regle | 100120

Niveau | 10

Source | Logs applicatifs

Risque | Atteinte confidentialite

Donnee concerne | Dossier patient fictif

Reponse attendue : verifier le role du compte, analyser le volume d'accès, suspendre temporairement si necessaire, prevenir le responsable client et conserver les traces.

Ce scenario montre que le SOC ne surveille pas seulement la technique, mais aussi les risques metier.

Page 34 - Scenario 4 : Modification groupe privilege

La modification d'un groupe privilege est une alerte critique. Elle peut indiquer une elevation de privileges, une persistance ou une mauvaise manipulation administrative.

Element | Detail

Regle | 100130

Niveau | 14

Source | Logs AD simules

Technique MITRE | T1098

Risque | Prise de controle du SI

Reponse attendue : verifier si l'action etait planifiee, identifier le compte auteur, retirer le compte si non autorise, auditer les changements recents et documenter l'incident.

Cette alerte doit etre traitee prioritairement par le SOC.

Page 35 - Scenario 5 : Usage USB

L'usage USB peut être légitime ou dangereux. Dans un environnement manipulant des données sensibles, il doit être surveillé.

Element | Detail

Regle | 100140

Niveau | 7

Source | Logs endpoint

Risque | Exfiltration ou introduction malware

Reponse | Verification politique USB

Reponse attendue : identifier le poste et l'utilisateur, vérifier le périphérique, demander justification, analyser le poste si nécessaire et rappeler la politique interne.

Ce scénario est moins critique qu'une élévation de privilèges, mais il montre une surveillance utile des postes utilisateurs.

Page 36 - Scenario 6 : Phishing

Le phishing est une menace importante pour le client. Meme si l'integration messagerie complete reste une perspective, le scenario doit etre documente.

Signaux possibles :

- email suspect ;
- domaine expéditeur inconnu ;
- piece jointe dangereuse ;
- lien de connexion frauduleux ;
- clic utilisateur ;
- execution suspecte apres reception.

Reponse attendue : identifier les destinataires, rechercher les emails similaires, bloquer le domaine, analyser les postes exposes, reinitialiser les mots de passe si necessaire et sensibiliser les utilisateurs.

Ce scenario peut etre relie a l'alerte PowerShell suspecte.

Page 37 - Scenario 7 : Scan reseau

Un scan reseau correspond a une phase de reconnaissance. Il peut precéder une attaque plus serieuse.

Sources utiles :

- logs firewall ;
- IDS type Suricata ;
- connexions refusees ;
- multiplicité des ports testes ;
- IP source externe ou interne.

Reponse attendue : identifier la source, verifier si elle est legitime, bloquer si externe malveillante, investiguer si interne, rechercher d'autres evenements lies.

Ce scenario est une evolution pertinente si une sonde IDS est ajoutée au MVP.

Page 38 - Processus de reponse incident

Le processus SOC suit une sequence simple.

1. Detection de l'alerte.
2. Qualification par l'analyste.
3. Enrichissement avec contexte.
4. Decision : faux positif ou incident.
5. Application du playbook.
6. Documentation des preuves.
7. Cloture ou escalade.
8. Amelioration de la regle.

Ce processus doit etre commun a tous les scenarios. Il garantit une reaction coherente et evite l'improvisation.

Les playbooks Markdown servent de support operationnel. Ils doivent etre mis a jour apres chaque REX.

Page 39 - Playbooks

Les playbooks disponibles couvrent les principaux incidents :

Playbook | Objectif

Brute force | Bloquer ou qualifier une tentative d'accès.

Execution suspecte | Analyser un processus ou script dangereux.

USB suspect | Verifier un support amovible.

Acces dossier patient | Protéger les données sensibles.

Phishing | Traiter un email suspect.

Scan reseau | Reagir a une reconnaissance.

Chaque playbook doit contenir : déclencheur, criticité, procédure, preuves à conserver et améliorations possibles.

Cette formalisation montre une posture professionnelle de SOC externalisée.

Page 40 - Preuves sprint 01

Le sprint 01 a produit des preuves techniques importantes.

Preuve | Emplacement

Etat conteneurs | livrables/preuves/sprint-01/docker-compose-ps.txt

Etat services Wazuh | livrables/preuves/sprint-01/wazuh-manager-status.txt

Regles locales | livrables/preuves/sprint-01/daylight-local-rules.txt

Logs presents | livrables/preuves/sprint-01/daylight-log-files.txt

Alertes detectees | livrables/preuves/sprint-01/daylight-alerts-table.md

Extrait alertes | livrables/preuves/sprint-01/alerts-tail.txt

Captures dashboard | livrables/preuves/sprint-01/captures-dashboard/

Script SIEM Youssef | scripts/setup-siem-lab.ps1

Documentation SIEM Youssef | livrables/youssef/supports/Documentation_SIEM_Youssef_GUERNIOU.pdf

Les captures visuelles du dossier captures-dashboard/ permettent de montrer la supervision globale, la liste des alertes et le detail des alertes principales 100100 a 100160.

Page 41 - Methodologie de test

La methode de test doit etre reproductible.

Pour chaque scenario :

1. Identifier la source de log.
2. Generer ou rejouer l'evenement.
3. Verifier que Wazuh recoit le log.
4. Verifier que la regle se declenche.
5. Capturer l'alerte.
6. Appliquer le playbook.
7. Rediger le REX.

Cette approche permet de prouver la chaine complete. Elle evite aussi de confondre une simple generation de log avec une vraie detection SOC.

Chaque test doit laisser une trace dans le dossier livrables/preuves.

Page 42 - Coûts du MVP

Le MVP est conçu pour limiter les coûts.

Poste		Hypothèse		Coût direct
Wazuh		Open-source		0 EUR licence
Docker		Environnement local		0 EUR licence
Logs		Générés en interne		0 EUR
Documentation		Markdown/PDF		0 EUR
Hébergement demo		Machine locale		0 EUR si disponible

Le coût principal du MVP est le temps humain : installation, configuration, tests, documentation, vidéo et mise en forme.

Ce choix est cohérent pour un projet d'études. Il permet de concentrer l'effort sur la valeur SOC plutôt que sur des licences.

Page 43 - Coûts de production

En production, les coûts changeraient.

Poste | Description

Infrastructure | Serveurs SOC, stockage, sauvegardes.

Exploitation | Temps analyste, supervision, astreinte.

Deploiement | Installation agents et configuration syslog.

Maintenance | Mises à jour, durcissement, tests.

Reporting | Rapports mensuels et comités client.

Le coût dépendrait du nombre de postes, du volume de logs, de la rétention, du niveau de service et du niveau d'automatisation.

La standardisation réduit les coûts : templates, checklist, scripts, conventions et dashboards réutilisables.

Page 44 - Planning projet

Le planning se decoupe en phases.

Phase | Objectif

Cadrage | Comprendre le besoin et definir le MVP.

Architecture | Concevoir le SOC et les flux.

Deploiement | Installer Wazuh et les sources de logs.

Detection | Creer regles et alertes.

Reponse | Rediger playbooks et REX.

Documentation | Finaliser rapport, guides et annexes.

Video | Presenter le MVP et les preuves.

La regle de pilotage est simple : aucune fonctionnalite n'est terminee sans preuve technique, preuve documentaire et moment de demonstration.

Page 45 - Risques projet

Risque | Impact | Mitigation

Wazuh instable | Demo bloquee | Logs rejouables et captures preparees.

Perimetre trop large | Rapport superficiel | Se concentrer sur scenarios prioritaires.

Manque de captures | Preuves faibles | Dossier preuves centralise.

Regles trop bruyantes | Alertes peu exploitables | Ajuster seuils et exceptions.

Retard documentation | Rendu incomplet | Documenter a chaque sprint.

Le risque le plus important est de vouloir tout faire. Le projet doit rester centre sur une chaine SOC complete et demonstrable.

Page 46 - Industrialisation et onboarding

Pour passer a 30 sites, il faut un processus d'onboarding.

Etapas proposees :

1. Recenser les actifs du site.
2. Declarer le site dans l'inventaire.
3. Installer les agents.
4. Configurer les firewalls en syslog.
5. Integrer les applications metier.
6. Tester une alerte.
7. Valider le dashboard par site.
8. Ajouter le site au reporting.

Chaque site doit suivre la meme checklist. Cela reduit les erreurs et facilite l'exploitation.

Page 47 - Scalabilite et retention

La scalabilite depend du volume de logs, du nombre de sites et de la duree de retention.

Sujet | Question

Volume | Combien d'evenements par jour et par site ?

Retention | Combien de temps conserver les logs ?

Stockage | Quelle taille d'index prevoir ?

Performance | Combien de dashboards et recherches simultanees ?

Disponibilite | Faut-il une architecture haute disponibilite ?

Pour une production, il faudrait realiser un dimensionnement plus precis. Le MVP ne remplace pas cette etude, mais il fournit une base technique et methodologique.

Page 48 - Sécurisation de la plateforme

Le SOC lui-meme doit etre securise. Une compromission du SIEM donnerait une vision sensible de l'ensemble du SI client.

Mesures recommandees :

- comptes nominatifs ;
- mots de passe robustes ;
- RBAC supervision / analyste / admin ;
- role lecture seule soc_readonly pour analyste et supervision dans le lab ;
- acces dashboard restreint ;
- sauvegardes de configuration ;
- mises a jour regulieres ;
- supervision des services Wazuh ;
- journalisation des actions admin.

La securite de la plateforme doit etre documentee dans le guide d'exploitation. Le SIEM ne doit pas devenir un point faible.

Page 49 - Limites et perspectives

Limites actuelles :

- logs simules ou rejoues ;
- captures Wazuh live disponibles, dont Data Explorer, Threat Hunting et l'alerte firewall/syslog 100160 ;
- pas de deploiement reel sur 30 sites ;
- pas de haute disponibilite ;
- messagerie encore partiellement simulee ;
- pas de SOAR integre.

Perspectives :

- agents reels sur VMs ;
- Suricata pour IDS ;
- TheHive pour ticketing ;
- Shuffle pour automatisation ;
- MISP pour threat intelligence ;
- dashboards par role ;
- reporting client automatise ;
- haute disponibilite.

Ces limites ne remettent pas en cause le MVP. Elles cadrent simplement la trajectoire d'evolution.

Page 50 - Conclusion et annexes

Le projet demontre la faisabilite d'un SOC externalise open-source pour un reseau d'audioprothesistes. Le MVP repose sur Wazuh, des logs realistes, des regles personnalisees, des alertes, des playbooks et une documentation structuree.

La valeur principale est la chaine complete : collecter, detecter, qualifier, repondre et documenter. Cette chaine est plus importante qu'une accumulation d'outils.

Annexes a joindre :

- schemas Mermaid ;
- regles Wazuh ;
- logs de demonstration ;
- preuves sprint 01 ;
- captures dashboard ;
- playbooks ;
- REX incidents ;
- guide de deploiement ;
- script SIEM Youssef ;
- documentation SIEM Youssef ;
- rendus individuels ;
- script video.

Les annexes livrees permettent de verifier la coherence entre cahier des charges, logs, regles, alertes, playbooks, rapport et video de demonstration.